

Ubuntu Bridge Initiative · Cybersecurity Internship · Cohort 1 · Stage 3 Capstone

Editable template — Deliverable 5 of 5: The Incident Response Report (PICERL). This is the document Sankofa's response stands or falls on — Legal, the board, and the regulator all read it. It follows the NIST SP 800-61r2 PICERL lifecycle, and it folds in your triage, timeline, IOCs, and ATT&CK map. Minimum 1,500 words. Submit the Google Doc link + a 100+ word abstract in the answer box. Edit in Google Docs (recommended). Replace every [BRACKETED] prompt and delete every grey guidance line before you submit.

Deliverable 5 — Incident Response Report (PICERL)

Before you start

- Audience: **Legal, the board, the regulator.** Facts, impact, decisions — keep raw log lines in the appendix and reference them.
- Use the **exact section headings below, in this order** (NIST SP 800-61r2 PICERL). Graders look for them by name.
- It must be **internally consistent** with your D1–D4: the timeline, the IOCs, the root cause all match.
- **Minimum 1,500 words.** No section shorter than two sentences; no section longer than ~350 words except the appendix and the timeline.
- **Citations required (8+):** NIST SP 800-61r2 by section number, 4+ MITRE ATT&CK technique IDs, 1+ CISA playbook, 1+ detection-engineering reference (Sigma / Wazuh / osquery / Falco / Atomic Red Team), and one sentence flagging **NDPA 2023 §40** applicability.

This is a scaffold, not an answer key. The analysis is yours; this gives you the section order and the bar graders expect.

What you submit

A Google Doc ("e1,500 words), sharing set to **Anyone with the link !' Viewer.** In the answer box paste the **Doc URL + a 100+ word abstract.** The report itself contains the sections below.

First line of your document:

Stage 3 · Incident report · [Your Full Name] · [UBI-2026-####]

Required sections (these headings, in this order)

1. **Executive summary** ("d200 words) — [what happened in plain language, what was lost/exposed, what is contained, what is NOT yet contained, and the action the board is asked to authorise. A reader who stops here can still brief their boss.]
2. **Scope** — [hosts, users, and data classes in scope (and out of scope) — one short paragraph each.]
3. **Preparation — what worked / what didn't** — [Sankofa's pre-incident posture. Did detection catch the beacon? Was the sudoers .d change reviewed? Cite the evidence for each control that was present or absent.]
4. **Identification — how we found it** — [the detection that triggered investigation; the forensic artefacts you pulled (memory dump, filesystem index, syslog, SIEM, netflow); chain of custody.]
5. **Containment — what stopped the bleeding** — [hosts isolated, credentials rotated, network rules pushed, and the ORDER you did them in — justify each ordering choice.]
6. **Eradication — what got removed** — [the persistence removed (the .bashrc source line, the .helper binary, the autostart entry, the cron); the sudoers entry fixed; any pivoted credentials revoked; the C2 domain gri0t-c2.dynamic-update.net sinkholed/blocked.]
7. **Recovery — how we returned to normal** — [reimage vs in-place clean; restore vs rebuild; the validation step that confirmed eradication (fresh image, fresh keys, monitored 72h with no

beacons).]

8. **Lessons learned — three actions** — [three concrete actions, each with a named owner ROLE and a deadline, each backed by an artefact in this incident. Not platitudes.]
9. **Timeline table** — [reuse/refine your D2 timeline. Columns exactly: Timestamp UTC | Event | Evidence (path or tab:timestamp) | ATT&CK ID | Confidence (H/M/L) | Confidence rationale ("d25 words")
Minimum 12 rows. H = direct evidence; M = correlated/indirect; L = inferred from absence. A table that is all H is wrong — real IR has uncertainty.]
10. **ATT&CK map summary** — [reference your D4; restate the **top 6** techniques here with a one-line justification each.]
11. **Risk register update** — [three NEW risks this incident surfaces — e.g. "unreviewed sudoers grants survive indefinitely" — each with likelihood × impact and a proposed control. Not "we got breached."]
12. **References (8+)** — [NIST SP 800-61r2 by section (e.g. §2 lifecycle, §3.3.4 containment); 4+ MITRE ATT&CK IDs; 1+ CISA playbook; 1+ detection reference; NDPA 2023 §40 with a one-line note on whether this breach meets the notification threshold.]
13. **Evidence appendix** — [every file, tab, timestamp, command, ATT&CK ID, and external reference cited above, in one numbered list.]
14. **Rejected alternate theory (80+ words)** — [one plausible explanation you considered and REJECTED, with the artefact that ruled it out. Generic "I considered other theories" scores zero. Example shape: "I considered direct insider abuse by o.adegoke — ruled out by [the artefact that disproves it]."]
15. **One mistake I almost made (80+ words)** — [a specific drafting moment: the order of containment vs eradication, nearly understating the blast radius, or missing logs misleading you. This goes **inside the Doc** — it is a section of the report, not the answer-box abstract. Vague answers score zero.]

Where the marks are won (what we look for)

- **A stand-alone executive summary** — a board member could act on it without reading further.
- **All sections present, in order, named correctly** — and 1,500+ words.
- **Root cause as a cause** — the compromised SSH key + the sudo less misconfiguration becoming persistent root — not "malware ran."
- **A real timeline table** — 12+ rows, with honest H/M/L confidence (not everything H) and ATT&CK IDs.
- **Owned, dated lessons + a real risk register** — actions with owner roles and deadlines; risks that are not just "we got breached."
- **The rejected-theory and one-mistake sections are specific** — these are the AI-resistant sections; generic answers score zero.
- **8+ real citations** — NIST by section, ATT&CK IDs, CISA, a detection reference, NDPA §40 — and consistency with your D1–D4.

Before you submit, confirm

- [] First line is the Stage 3 · Incident report · Name · Code identity line.
- [] All 15 sections present, in order, with the exact headings; 1,500+ words.
- [] Timeline table has 12+ rows with the six columns incl. Confidence (not all H).
- [] Rejected-alternate-theory and one-mistake sections are specific and inside the Doc.
- [] 8+ citations incl. NIST §, 4+ ATT&CK IDs, CISA, a detection ref, and NDPA §40.
- [] Doc sharing is "Anyone with the link !' Viewer"; answer box has the URL + 100-word abstract.
- [] No [BRACKETED] prompts or grey guidance lines remain.